System Documentation — Hotel Management System

Backend Documentation

Author: Ahmed Shaain Firaq | S2401269

1. System Architecture Overview

The Hotel Management System backend is built using a layered architecture pattern with ASP.NET Core 9 Web API. The system is divided into four distinct layers:

Presentation Layer (Controllers)

Handles incoming HTTP requests and returns appropriate responses. Each controller is responsible for a specific domain area and delegates business logic to the service layer.

Business Logic Layer (Services)

Contains all business rules and logic. Services are injected into controllers via dependency injection and communicate with the data layer through Entity Framework Core.

Data Layer (AppDbContext + Models)

Manages database communication using Entity Framework Core with PostgreSQL. All database entities are defined as C# model classes with relationships configured using Fluent API.

Security Layer (Middleware)

Handles cross-cutting concerns including JWT authentication, role-based access control, session timeout and account lockout.

Request Flow:

```
Client Request
     ↓
Middleware (JWT + RBAC + Session Timeout)
     ↓
Controller (AuthController, RoomController, BookingController...)
     ↓
Service (AuthService, RoomService, BookingService...)
     ↓
AppDbContext (Entity Framework Core)
     ↓
PostgreSQL Database
```

2. Tech Stack

Component	Technology	Version
Backend Framework	ASP.NET Core Web API	9.0
Language	C#	13
ORM	Entity Framework Core	9.0.1
Database	PostgreSQL	17
DB Driver	Npgsql	9.0.4
Authentication	JWT Bearer	9.0.0
Password Hashing	BCrypt.Net-Next	4.0.3
API Documentation	Swashbuckle (Swagger)	6.9.0

3. Database Documentation

3.1 Database Schema Overview

The system uses 8 database tables managed by Entity Framework Core migrations. All tables are created automatically on application startup via the EF Core migration applied in Program.cs.

3.2 Table Descriptions

Users

Stores all system user accounts across all roles.

Column	Type	Description
Id	int (PK)	Auto-generated primary key
FullName	varchar	User's full name
Email	varchar (UNIQUE)	User's email — used for login
PasswordHash	varchar	BCrypt hashed password
Role	varchar	Guest / Staff / Manager / Admin
IsLocked	boolean	Whether account is locked
FailedLoginAttempts	int	Count of consecutive failed logins
LockoutEnd	timestamp?	When lockout expires (nullable)
CreatedAt	timestamp	Account creation date

Hotels

Stores hotel property information.

Column	Type	Description
Id	int (PK)	Auto-generated primary key
Name	varchar	Hotel name
Location	varchar	Hotel location
Description	text	Hotel description
PhoneNumber	varchar	Contact number
Email	varchar	Contact email

Rooms

Stores all room details for each hotel.

Column	Type	Description
Id	int (PK)	Auto-generated primary key
HotelId	int (FK)	References Hotels table
RoomNumber	varchar	Room number identifier
RoomType	varchar	Standard / Deluxe / Family Suite / Penthouse
Capacity	int	Maximum number of guests
PricePerNightOffPeak	decimal	Off-peak nightly rate (£)
PricePerNightPeak	decimal	Peak season nightly rate (£)
Status	varchar	Available / Occupied / Cleaning / OutOfService
Description	text	Room description
ImageUrl	varchar	Room image URL

Bookings

Stores all guest booking records.

Column	Type	Description
Id	int (PK)	Auto-generated primary key
UserId	int (FK)	References Users table
RoomId	int (FK)	References Rooms table
CheckInDate	timestamp	Scheduled check-in date
CheckOutDate	timestamp	Scheduled check-out date
NumberOfGuests	int	Number of guests
TotalPrice	decimal	Total booking price (£)
CancellationFee	decimal	Fee applied on cancellation (£)

Column	Type	Description
Status	varchar	Confirmed / CheckedIn / CheckedOut / Cancelled / NoShow
SpecialRequests	text	Guest special requests
BookedAt	timestamp	Booking creation timestamp

Payments

Stores payment records for bookings.

Column	Type	Description
Id	int (PK)	Auto-generated primary key
BookingId	int (FK)	References Bookings table (one-to-one)
Amount	decimal	Amount paid (£)
PaymentMethod	varchar	Card / Cash
Status	varchar	Pending / Completed / Refunded
PaidAt	timestamp	Payment timestamp

AncillaryServices

Stores optional add-on services available to guests.

Column	Type	Description
Id	int (PK)	Auto-generated primary key
ServiceName	varchar	Airport Transfer / Breakfast / Spa / Late Checkout
Fee	decimal	Service fee (£)
Description	text	Service description
IsPerPerson	boolean	Whether fee applies per person
IsPerDay	boolean	Whether fee applies per day

BookingServices

Junction table linking bookings to ancillary services.

Column	Type	Description
Id	int (PK)	Auto-generated primary key
BookingId	int (FK)	References Bookings table
AncillaryServiceId	int (FK)	References AncillaryServices table
Quantity	int	Number of units

Column	Type	Description
TotalFee	decimal	Calculated total fee (£)

AuditLogs

Records all key system actions for security monitoring.

Column	Type	Description
Id	int (PK)	Auto-generated primary key
UserId	int? (FK)	References Users table (nullable)
Action	varchar	Login / Booking / Payment / CheckIn / CheckOut / Cancellation
Details	text	Detailed description of the action
IpAddress	varchar	Client IP address
Timestamp	timestamp	When the action occurred

3.3 Table Relationships

Relationship	Type	Description
Hotel → Rooms	One to Many	One hotel has many rooms
User → Bookings	One to Many	One user can have many bookings
Room → Bookings	One to Many	One room can have many bookings over time
Booking → Payment	One to One	Each booking has one payment
Booking → BookingServices	One to Many	A booking can have multiple services
AncillaryService → BookingServices	One to Many	A service can appear in many bookings
User → AuditLogs	One to Many	A user can have many audit log entries

4. API Endpoints Documentation

4.1 Authentication Endpoints

Method	Endpoint	Description	Access
POST	/api/Auth/register	Register a new guest account	Public
POST	/api/Auth/login	Login and receive JWT token	Public

Register Request Body:

```
{ "fullName": "John Smith", "email": "john@example.com", "password": "Password@123" }
```

Login Response:

```
{ "token": "eyJhbGc...", "fullName": "John Smith", "email": "john@example.com",
"role": "Guest" }
```

4.2 Room Endpoints

Method	Endpoint	Description	Access
GET	/api/Room/search	Search available rooms	Public
GET	/api/Room/{id}	Get room by ID	Public
GET	/api/Room	Get all rooms	Staff+
PATCH	/api/Room/{id}/status	Update room status	Staff+

Search Query Parameters: hotelId, checkInDate, checkOutDate, roomType, capacity

4.3 Booking Endpoints

Method	Endpoint	Description	Access
POST	/api/Booking	Create a new booking	Guest+
GET	/api/Booking/my	Get current user's bookings	Guest+
GET	/api/Booking/{id}	Get booking by ID	Guest+
DELETE	/api/Booking/{id}	Cancel a booking	Guest+
GET	/api/Booking	Get all bookings	Staff+
POST	/api/Booking/{id}/checkin	Check in a guest	Staff+
POST	/api/Booking/{id}/checkout	Check out a guest	Staff+
GET	/api/Booking/arrivals/today	Today's arrivals list	Staff+
GET	/api/Booking/departures/today	Today's departures list	Staff+
POST	/api/Booking/payment	Process payment for booking	Staff+

4.4 Report Endpoints

Method	Endpoint	Description	Access
GET	/api/Report/dashboard	Dashboard summary statistics	Staff+
GET	/api/Report/occupancy	Occupancy report by date range	Manager+
GET	/api/Report/revenue	Revenue report by date range	Manager+

4.5 Audit Endpoints

Method	Endpoint	Description	Access
GET	/api/Audit	Get audit logs with optional filters	Admin/Manager

Query Parameters: action, userId, from (date), to (date)

5. Security Implementation

5.1 JWT Authentication

The system uses JSON Web Tokens (JWT) for stateless authentication. When a user logs in successfully, the server generates a signed JWT token containing the user's ID, email, name and role as claims.

Setting	Value
Token Expiry	15 minutes
Signing Algorithm	HMAC SHA-256
Issuer	HMS.API
Audience	HMS.Client

All protected endpoints require the token in the Authorization header:

```
Authorization: Bearer eyJhbGc...
```

5.2 Role-Based Access Control (RBAC)

The system implements four roles with increasing levels of access:

Role	Access Level	Description
Guest	Basic	Can search rooms, make/view/cancel own bookings, update profile
Staff	Elevated	All Guest permissions + check-in/out, room management, process payments
Manager	Management	All Staff permissions + occupancy/revenue reports, manage room rates
Admin	Full	All permissions + user management, hotel configuration, view audit logs

5.3 Account Lockout Policy

After 5 consecutive failed login attempts, the account is automatically locked for 15 minutes. All lockout events are recorded in the AuditLogs table. The failed attempt counter resets on successful login.

5.4 Session Timeout

JWT tokens expire after 15 minutes from the time of issue. The SessionTimeoutMiddleware validates token expiry on every incoming request. Expired tokens return a 401 Unauthorized response with the message: 'Session expired. Please log in again.'

5.5 Audit Logging

The AuditService automatically records the following key system events:

Event	Trigger
Register	New user self-registration
Login	Successful user login
FailedLogin	Failed login attempt recorded with count
AccountLocked	Account locked after 5 consecutive failures
Booking	New booking created
Cancellation	Booking cancelled with calculated fee
CheckIn	Guest successfully checked in by staff
CheckOut	Guest successfully checked out by staff
Payment	Payment processed for a booking

5.6 Password Security

All passwords are hashed using BCrypt with a work factor of 10 before storage. Plain text passwords are never stored in the database. BCrypt's adaptive cost factor provides protection against future hardware improvements.

6. Business Logic

6.1 Cancellation Fee Engine

The BookingService.CalculateCancellationFee() method applies the following rules based on how far in advance the cancellation is made:

Notice Period	Cancellation Fee
More than 14 days before check-in	Free (£0)

Notice Period	Cancellation Fee
3 to 14 days before check-in	50% of first night's rate
Less than 72 hours before check-in	100% of first night's rate
No-show	100% of entire booking value

6.2 Peak / Off-Peak Pricing

The RoomService.IsPeakSeason() method determines pricing based on the check-in month:

Season	Months	Price Applied
Peak Season	June, July, August, December	PricePerNightPeak
Off-Peak Season	All other months	PricePerNightOffPeak

6.3 Room Availability

When searching for rooms, the system excludes any room that has an existing non-cancelled booking where the dates overlap with the requested check-in and check-out dates. This prevents double bookings by checking: existing CheckInDate < requested CheckOutDate AND existing CheckOutDate > requested CheckInDate.

7. Seed Data

The DataSeeder class automatically seeds the following data on first application startup:

Category	Count	Details
Hotels	2	The Grand London (London, UK), Paris Elite (Paris, France)
Rooms	20	10 per hotel — Standard, Deluxe, Family Suite, Penthouse
Ancillary Services	4	Airport Transfer (£50), Breakfast (£20/person/day), Spa (£35/person/day), Late Checkout (£40)
Users	5	Admin, Manager, Staff, Guest (x2) — one per role

Test account credentials are documented in instructions.txt included with the submission.